

System Security Plan

Sentinel Nexus — Autonomous Agentic SOC Platform

RW

June 2026

Contents

Document Control	2
1. System Identification & Categorization	3
2. System Description & Architecture	3
3. NIST SP 800-53 Rev. 5 — Control Implementation Summary	5
4. NIST CSF 2.0 — Function Implementation	10
5. AI-Specific Controls (NIST AI 600-1 / AI RMF)	10
6. Plan of Action & Milestones (POA&M)	11
7. Roles & Responsibilities	11
Appendix A — Control Cross-Reference	13

Document Control

Field	Value
Document title	System Security Plan (SSP) — Sentinel Nexus
Version	1.0
Date	2026-06-12
Classification	Public
System owner	The man, the myth, the legend
Authorizing official	(assign at ATO)
Review cadence	Quarterly, or on material architecture change
Frameworks	NIST SP 800-53 Rev. 5 · NIST CSF 2.0 · NIST AI 600-1 (GenAI Profile) / AI RMF 1.0

Companion documents: `security_controls.md` (control manifest), `nist_ai_600_1_control_tracker.` (AI control implementation status), and the governance set in this directory (AI system inventory, GAI risk-tier statement, incident response plan, data-retention/decommission policy, applicability determinations, environmental-impact estimate).

1. System Identification & Categorization

System name: Sentinel Nexus — an autonomous, air-gap-capable agentic Security Operations Center (SOC) platform that detects, investigates, and contains threats at machine speed across a 50,000+ endpoint estate.

Operating model: sovereign / on-premises or single-tenant cloud, with an air-gapped deployment mode (NEXUS_OFFLINE_MODE) in which no telemetry or model egress crosses the enclave boundary.

Security categorization (FIPS-199 style):

Objective	Impact	Rationale
Confidentiality	High	Processes security telemetry, credentials in transit, and threat-intel; a breach exposes the defended estate’s posture.
Integrity	High	Drives autonomous containment; tampered verdicts or models could disrupt production or suppress detection.
Availability	Moderate	Detection latency is operationally important, but the platform fails safe (degrades to monitoring) rather than mis-acting.

Overall categorization: HIGH.

2. System Description & Architecture

A four-tier correlation engine that shifts the kill chain left:

- **Layer 1 — Vector tripwires.** Rust workers map normalized UEBA telemetry into Qdrant HNSW indices; cosine-similarity anomalies (zero-days, living-off-the-land) trigger downstream analysis.
- **Layer 2 — Deterministic engine.** A zero-copy Rust worker evaluates Sigma-style rules over the NATS JetStream Parquet bus.
- **Layer 3 — Agentic closer (LLM Hunter swarm).** A LangGraph DAG — supervisor → host/net/cloud/nettap experts → adversarial review board → response agent — performs bounded, read-only forensic pivots over cold storage (DuckDB/Parquet), Qdrant, threat intel, and the enterprise SIEMs (Splunk/Elastic), reaching a governed verdict that drives SOAR.
- **Sovereign Threat Intel.** Air-gapped OpenCTI 6.8 (MITRE ATT&CK pre-loaded).

Model inventory (developer + deployer roles): four fine-tuned models (A: network baseline LSTM-AE; B: adversarial pattern classifier; C: spatial endpoint expert; D: SOAR critic / blast-radius evaluator) plus optional frontier models (Anthropic / Azure) in a sovereign-by-default failover chain. Full detail in the AI System Inventory.

Authorization boundary: the Nexus enclave — ingestion gateway, NATS cluster, Redis, Qdrant, MinIO/S3 cold storage, the Rust worker fleet, the middleware ETL fanout, the LLM Hunter swarm, the MLOps training/serving planes, the Det Chamber detonation sandbox, and the SOAR/operations interface. External SIEMs, frontier model APIs, and external TI providers are **interconnections**, not in-boundary.

2.1 Secure Data Ingestion & Transmission Path

Telemetry enters the enclave through a **Zero-Trust ingestion gateway** (`services/core_ingress`, an Axum service) that treats every sensor as untrusted until cryptographically proven. The path enforces defense-in-depth *before* a single event reaches the bus or storage (SC-7, SC-8, SC-16, SI-7, SI-10):

1. **Transport security (SC-8).** Mutual TLS termination at HAProxy to the gateway; JWT bearer authorization (minted per ingress node, audience-scoped) gates the API.
2. **Cryptographic lineage integrity (SI-7, SC-16).** Every Rust sensor stamps each Parquet batch with an HMAC-SHA256 `nexus_integrity` tag over a **canonical byte order** — `parquet || seq_BE || sensor_id || ts_BE` (big-endian sequence and timestamp) — keyed by a Vault-provisioned `integrity_secret`. The gateway recomputes and verifies it; a mismatch is rejected. (A historical bug where the stamp used little-endian / wrong field order silently 400-banned every Rust sensor; it was found, fixed, and is now contract-tested.)
3. **Three-tier replay & tamper defense (SI-10, SC-5).** Beyond the HMAC the gateway independently validates **temporal drift** (timestamp within a bounded ± 30 s window — rejects replayed/back-dated batches), **monotonic sequence** (per-sensor counter must advance — rejects replay/reorder), and **cross-OS consistency + collision detection** on the lineage tuple.
4. **Input validation (SI-10).** Sensor-controlled `endpoint_id` values are regex-validated (`^[a-zA-Z0-9\-\_]{3,64}$`) in the Rust ingestion layer before reaching Qdrant or Parquet — blocking injection / path-traversal via sensor fields.
5. **Adaptive sensor banning (AC-7, SI-4).** Repeated integrity failures past `integrity_ban_threshold` trip a **persistent** ban (survives restarts), bounding a compromised or spoofing sensor's blast radius.
6. **Exactly-once downstream.** Accepted events deduplicate on `event_id` (7-day Redis SETNX); SOAR actions carry a 15-minute rolling idempotency key as a `Nats-Msg-Id` header so containment applies exactly once.

From the gateway, validated telemetry flows over **NATS JetStream** (default-deny subject authorization, 3-node quorum, durable consumers) to the Rust worker fleet (`worker_qdrant` vector tripwires, `worker_rules` Sigma, `worker_s3_archive` Hive-partitioned cold storage) and, via the **middleware ETL fanout**, to the enterprise SIEMs — each hop carrying OTLP trace context and DLQ routing for poison messages. A data-flow **conservation test** proves no event is silently dropped between hops.

3. NIST SP 800-53 Rev. 5 — Control Implementation Summary

Status legend: **I** implemented · **P** partial · **PL** planned.

3.0 Infrastructure Hardening (Infrastructure-as-Code, Layer 0)

A large share of the technical safeguards is enforced declaratively and idempotently by the hardening/ and infrastructure/ansible/roles/common_hardening roles, applied as the **first** play in `site.yml` (Layer 0) before any service is deployed — so no workload ever runs on an unhardened host. The IaC encodes a CIS-style baseline:

- **Kernel & network stack (SC-7, SC-5, SI-16).** `sysctl` baseline: full ASLR (`kernel.randomize_va_space=2`), `kernel.dmesg_restrict`, reverse-path filtering, TCP SYN cookies, ignore ICMP broadcasts / bogus responses, disable source routing, ICMP redirect accept/secure-redirects off, martian logging, and `fs.suid_dumpable=0` with core dumps disabled (`limits.conf` + `sysctl`).
- **Filesystem mount hardening (CM-7, AC-6).** `/tmp` and `/dev/shm` mounted `noexec,nosuid,nodev`; restrictive permissions on `/etc/crontab` and the cron directories; default `umask 077`.
- **SSH (AC-17, IA-2, SC-8).** Protocol 2, PermitRootLogin no, no password/empty/host-based auth, strong KEX/Ciphers/MACs only, AllowGroups allow-listing, bounded MaxAuthTries/MaxStartups/LoginGraceTime, idle ClientAlive timeout, X11/agent/TCP forwarding disabled, LogLevel VERBOSE, and a legal login banner.
- **Host firewall (SC-7).** Default-**DROP** `firewalld` zone (RHEL) / UFW (Debian) with an explicit service/port allow-list and a trusted-subnet rule; zone-drifting disabled.
- **Brute-force & integrity (SI-3, SI-7, SI-4).** `fail2ban` on auth surfaces; **AIDE** file-integrity monitoring; `auditd` enabled with a rule set watching the identity files (`/etc/passwd|shadow|group|gshadow|sudoers`), PAM, `su/sudo` execution, and the **Podman** runtime/socket/config — giving tamper-evident audit of the container control plane (AU-2, AU-12).
- **Account policy (AC-2, IA-5).** Password aging (max 60 / min 1 days, history 5, max 3 retries) via `login.defs`/PAM; root account locked.
- **Container least-functionality (CM-7, SC-39).** Rootless/daemonless Podman with `cgroup-v2` delegation and a `registries.conf` pull allow-list (`docker.io` + `localhost` only); minimal package install (security packages `aide/fail2ban/auditd` added, unnecessary services removed).

These Layer-0 mechanisms underpin the SC, SI, AC, AU, and CM families below; the service-tier controls in those tables build on this hardened substrate.

Access Control (AC)

Control	Status	Implementation
AC-2 Account management	I	Authentik IdP (OIDC), RBAC for operator personas; per-service NATS subject-level auth.

Control	Status	Implementation
AC-3 Access enforcement	I	Agent tool visibility is role-scoped (tools/__init__.py RBAC: per-expert kits, counterpart kit with no mutation/acquire). Read-only data-lake + SIEM sandboxes.
AC-4 Information flow enforcement	I	Sovereign-by-default egress: TI providers, frontier models, and SIEM backends are inert unless explicitly enabled + keyed; outbound DLP scrub.
AC-6 Least privilege	I	S3 creds scoped to GetObject; the host expert alone holds acquisition agency; counterparts cannot write entity state.

Audit & Accountability (AU)

Control	Status	Implementation
AU-2/AU-3 Auditable events / content	I	Structured incident reports (AI-provenance stamped), SOAR audit reason (DLP-scrubbed), Prometheus metrics, RSI/calibration/bias-audit ledgers.
AU-6 Audit review	P	Bias-audit job (NC-1) + calibration ledger (NC-2) provide periodic review signals; SIEM forwards mirror events.
AU-9 Protection of audit information	I	Append-only ledgers; DR snapshots to S3; reports tracked in version control.

Configuration Management (CM)

Control	Status	Implementation
CM-2 Baseline configuration	I	IaC (Ansible/Terraform), pinned container versions, <code>nexus.toml</code> single source of truth with cross-config contract tests.
CM-3 Change control	I	GitLab 7-stage CI/CD; deploy-blocking eval gates; per-section test harness (<code>run_tests.sh</code>).
CM-7 Least functionality	I	Read-only query sandboxes (DuckDB, SIEM), keyword/command allowlists, local-FS block.

Contingency Planning (CP)

Control	Status	Implementation
CP-9 System backup	I	Nightly Qdrant + Redis → S3 DR snapshots (7-day retention); Terraform remote state.
CP-10 Recovery	I	Durable worker circuit breaker + DLQ; supervised tokio restart; model registry re-pin rollback (planned, WS-A).

Identification & Authentication (IA)

Control	Status	Implementation
IA-2/IA-5 Authentication / authenticators	I	OIDC for operators; NATS user/pass per role; HMAC-SHA256 sensor integrity stamping; Vault-backed runtime secrets.

Incident Response (IR)

Control	Status	Implementation
IR-4 Incident handling	I	The platform is the incident-handling engine (detect → investigate → contain via SOAR) with HitL circuit breaker; cognitive-fault DLQ.
IR-5/IR-6 Monitoring / reporting	P	AI Incident Response Plan (this directory) defines AI-incident criteria + after-action template; formal external reporting pathway PL.

Risk Assessment (RA)

Control	Status	Implementation
RA-3 Risk assessment	I	NIST AI 600-1 gap analysis + control tracker; GAI risk-tier statement.
RA-5 Vulnerability monitoring	I	Red-team CI gate (cognitive bypass), AI red-teaming (garak/PyRIT scaffolds), dependency pinning (RUSTSEC), anchore scans in deployment-prep.

System & Communications Protection (SC)

Control	Status	Implementation
SC-7 Boundary protection	I	Zero-Trust Axum gateway (TLS, JWT, 3-tier integrity), HAProxy mTLS, default-deny NATS authz, k8s NetworkPolicy, isolated detonation network.
SC-8 Transmission confidentiality/integrity	I	TLS throughout; HMAC lineage stamping; canonical field-order integrity.

Control	Status	Implementation
SC-28 Protection at rest	I	Parquet cold storage on access-controlled MinIO/S3; SQLite buffers gitignored; secrets in Vault/Ansible-Vault.

System & Information Integrity (SI)

Control	Status	Implementation
SI-3 Malicious code protection	I	Det Chamber isolated detonation; cross-OS schema-injection corpus; sensor input regex validation.
SI-4 System monitoring	I	The detection mission itself; canary leak tripwire halts SOAR; conservation-tested data flow.
SI-7 Software/firmware/information integrity	I	SHA-384 model-weight verification at boot; SoarExecutionSchema output contract; review-board grounding control (cited evidence must resolve).
SI-10 Information input validation	I	Cognitive sanitizer (<untrusted_payload> wrapping, control-token defang, boundary isolation) on all adversary-controlled telemetry and SIEM results.

Supply Chain Risk Management (SR)

Control	Status	Implementation
SR-3/SR-4 Supply chain controls / provenance	I	SHA-384 weight manifests; pinned base images; air-gap bundle with SBOM/scan; frontier-model version-pin enforcement (NC-3).
SR-11 Component authenticity	I	Cryptographic model supply-chain integrity (ATLAS AML.T0044).

4. NIST CSF 2.0 — Function Implementation

Function	Coverage
GOVERN (GV)	AI governance via the NIST AI 600-1 control tracker + this SSP; GAI risk-tier statement; sovereign-by-default policy; roles & RBAC; supply-chain governance.
IDENTIFY (ID)	AI system inventory; asset criticality registry (TIER-1 assets force HitL); risk assessment (gap analysis); applicability determinations.
PROTECT (PR)	Zero-Trust gateway, RBAC, read-only sandboxes, DLP egress, encryption, secrets management, prompt-injection defenses, model-integrity verification.
DETECT (DE)	The core mission: 3-layer correlation (vector/rule/agentic), canary tripwires, conservation tracking, continuous monitoring.
RESPOND (RS)	Governed SOAR with HitL circuit breaker; cognitive-fault DLQ; AI incident response plan; review-board fail-closed verdicts.
RECOVER (RC)	DR snapshots; durable-worker recovery; FP-restore playbooks; planned model-registry re-pin rollback.

5. AI-Specific Controls (NIST AI 600-1 / AI RMF)

The platform is both a GAI **developer** (fine-tunes Models A-D) and **deployer** (runs frontier + local inference). Implementation status is maintained in `nist_ai_600_1_control_tracker.m` highlights:

- **Confabulation (2.2):** review-board evidence-grounding (cited artifacts must

resolve to retrieved evidence); deterministic regression gate; confidence calibration ledger (NC-2).

- **Information Security (2.9):** the platform’s strongest area — canary, boundary isolation, read-only sandboxes, supply-chain hashing, DLQ.
- **Harmful Bias & Homogenization (2.6):** disaggregated fairness audit + immunity- memory homogenization monitor, run as a scheduled control (NC-1).
- **Human-AI Configuration (2.7):** HitL circuit breaker, AI-origin disclosure on reports, TIER-1 manual review.
- **Value Chain (2.12):** frontier-model version-pin enforcement (NC-3), supply-chain integrity, weight manifests.

The misuse / content-generation risk families (CBRN, CSAM/NCII, dangerous/obscene content, IP infringement) are determined **not applicable** — the platform consumes adversary telemetry and emits internal SOC verdicts; it is not a public content generator. See the Applicability Determinations document.

6. Plan of Action & Milestones (POA&M)

ID	Item	Control	Target
POAM-1	Schedule + alert the bias/homogenization audit and calibration ledger jobs	AU-6, RA-3	next sprint
POAM-2	Formalize external AI-incident reporting pathway	IR-6	next sprint
POAM-3	Model registry + steward (pull-based promotion, re-pin rollback)	CM-3, CP-10	WS-A B2.5
POAM-4	RAG-memory retention enforcement + membership-inference review	SC-28, AU-9	per retention policy
POAM-5	Live integration tests in CI (gateway+NATS+Qdrant)	CA-2	hardware-gated

7. Roles & Responsibilities

Role	Responsibility
System owner	Accepts residual risk; approves the SSP and ATO.
AI governance lead	Maintains the AI control tracker, risk-tier statement, applicability determinations.
Platform engineering	Implements + tests controls; runs the deploy gates.
SOC operators	Disposition verdicts (feeding calibration), action HitL escalations.
Authorizing official	Grants/maintains the authorization to operate.

Appendix A — Control Cross-Reference

This SSP summarizes; the authoritative, test-linked control detail lives in `security_controls.md` (manifest) and `nist_ai_600_1_control_tracker.md` (AI controls, with per-control proving tests). Every implementation claim in §3-§5 is backed by an automated test in the `tests/` harness and reported under `tests/reports/`.